

Email Authentication Guide: SPF, DKIM and DMARC

Study notes for email campaign operations

1. Why email authentication matters

Anyone can type any address into the From field of an email, which is why spammers and phishers can pretend to be a trusted brand. Email authentication is a set of DNS-based checks that lets a receiving mail server confirm that a message really came from a server allowed to send for that domain and that the content was not changed on the way. Mailbox providers such as Gmail, Yahoo and Outlook use these checks as a main input when deciding whether a message goes to the inbox, the spam folder or is rejected.

The three standards used together are SPF, DKIM and DMARC. Each one answers a different question, and a sender should set up all three on every sending domain.

2. SPF (Sender Policy Framework)

SPF stands for Sender Policy Framework. It lets the owner of a domain publish a list of the IP addresses and services that are allowed to send email for that domain. The list is stored in a DNS TXT record on the domain. When a message arrives, the receiving server looks at the envelope sender (the Return-Path or MAIL FROM domain), fetches that domain's SPF record and checks whether the connecting IP address is on the list.

```
example.com.  TXT  "v=spf1 ip4:203.0.113.10 ip4:203.0.113.11 include:_spf.espprovider.com ~all"
```

- **v=spf1** marks the record as SPF version 1.
- **ip4:** / **ip6:** authorises a specific IP address or range.
- **include:** authorises another provider's published sending servers.
- **~all** (softfail) means other senders are suspicious; **-all** (hardfail) means other senders must fail; **?all** means neutral.

Important SPF rules: a domain must have only one SPF record, and an SPF check is allowed at most 10 DNS lookups (include, a, mx, ptr and redirect each count). Going over 10 lookups produces a permanent error (PermError) and SPF fails. SPF also breaks when a message is forwarded, because the forwarding server's IP is not in the original domain's list.

3. DKIM (DomainKeys Identified Mail)

The purpose of DKIM is to let the sending domain digitally sign each outgoing message so that the receiver can verify two things: the message really was authorised by the signing domain, and the signed parts of the message (headers and body) were not modified in transit. The sending server signs the message with a private key. The matching public key is published in a DNS TXT record under a name that includes a selector, and the receiver uses it to check the signature.

```
selector1._domainkey.example.com.  TXT  "v=DKIM1; k=rsa; p=MIIBIjANBgkqh...(public key)..."
```

The DKIM-Signature header in the email contains the signing domain (d=), the selector (s=), the list of signed headers (h=) and the signature itself (b=). Using a selector makes it possible to have several keys for one domain and to rotate keys without downtime. Most providers recommend 2048-bit keys, and keys should be rotated regularly. Unlike SPF, DKIM normally survives forwarding because the signature travels with the message.

4. DMARC (Domain-based Message Authentication, Reporting and Conformance)

DMARC builds on SPF and DKIM. It tells receivers what to do when a message fails authentication and gives the domain owner reports about who is sending mail using the domain. DMARC adds the idea of alignment: the domain in the visible From address must match the domain that passed SPF (the Return-Path domain) or the domain that passed DKIM (the d= domain). A message passes DMARC if SPF or DKIM passes AND that passing check is aligned with the From domain.

```
_dmarc.example.com. TXT "v=DMARC1; p=none; rua=mailto:dmarc-reports@example.com; pct=100"
```

Policy	What the receiver is asked to do
p=none	Monitor only. Deliver the message normally but send reports. Used at the start to discover all senders.
p=quarantine	Treat failing messages as suspicious, usually by placing them in the spam folder.
p=reject	Reject failing messages during the SMTP conversation so they are never delivered. This is the strictest policy and gives the strongest protection against spoofing.

- **rua** is the address that receives daily aggregate reports (XML summaries of pass and fail counts per sending source).
- **ruf** is the address for forensic (failure) reports; many providers do not send them for privacy reasons.
- **pct** is the percentage of failing mail the policy applies to, which allows a gradual rollout.
- **adkim / aspf** set alignment to relaxed (r, subdomains allowed) or strict (s, exact match).

5. Recommended setup order

- Make a list of every system that sends mail for the domain (campaign platform, CRM, support desk, transactional service).
- Publish one SPF record that includes all of them and stays under 10 lookups.
- Turn on DKIM signing for each sender and publish the public key records.
- Publish DMARC with p=none and a rua address, then read the reports for a few weeks.
- Fix any legitimate source that fails, then move to p=quarantine and finally p=reject, raising pct step by step.

6. Common authentication problems and fixes

Problem	Typical cause	Fix
SPF fail or PermError	More than 10 DNS lookups, or two SPF records on one domain	Merge into one record, remove unused includes, use ip4 ranges
DKIM fail	Wrong selector, public key not published, message modified after signing	Check the selector in the header, re-publish the key, avoid footers added after signing
DMARC fail with SPF and DKIM passing	Alignment mismatch: From domain differs from Return-Path and d= domain	Use a custom Return-Path and DKIM domain that match the From domain

Problem	Typical cause	Fix
DNS changes not working	DNS propagation delay or TXT record typed with extra quotes or spaces	Wait for TTL, then re-check with a DNS lookup tool

Authenticating a domain does not guarantee inbox placement, but sending without authentication almost guarantees problems. SPF, DKIM and DMARC prove identity; reputation, list quality and content decide the final placement.